Incident final report

Simulated scenario written from the incident notes of the course. The dates, amounts and figures are the ones in the scenario.

Executive summary

On December 28, 2022, at 7:20 p.m. PT, the organization confirmed that someone had gained unauthorized access to customer personal data and financial information. About 50,000 customer records were exposed. The direct cost is estimated at $100,000, not counting the revenue we may lose. The incident has been investigated and is now closed.

Timeline

When	What happened
December 22, 2022, about 3:13 p.m. PT	An employee received an email from an outside address. The sender said they had stolen customer data and asked for $25,000 in cryptocurrency to keep it private. The employee took it for spam and deleted it.
December 28, 2022	The same sender wrote again, this time with a sample of the stolen data and a demand of $50,000. The employee reported it to the security team the same day, and the investigation started.
December 28 to 31, 2022	The security team worked on how the data was taken and how much of it.

Investigation

The security team came on site as soon as the alert arrived. The root cause was a weakness in the e-commerce web application. The purchase confirmation page showed an order number in its URL, and the application did not check that the order belonged to the person asking for it. By changing the number, the attacker could open other customers' confirmation pages. This is called forced browsing.

The web server access logs confirmed it. One single source had requested thousands of confirmation pages, one order after the other, at a rate no normal customer would reach. That is the pattern of a script collecting data, and it matches the sample the attacker sent us.

Response and remediation

The organization worked with the public relations department to tell the affected customers about the breach, and offered them free identity protection services.

Recommendations

1. Run vulnerability scans and penetration tests on a regular schedule, so a flaw like this is found by us first.

2. Use allowlisting, so the application only serves a defined set of URLs and blocks the rest automatically.

3. Make sure only authenticated users can reach content, and check on the server that each order belongs to the user who asks for it.

4. Add detection for the pattern we saw in the logs, many sequential requests from one source, and slow it down with rate limiting.

5. Tell employees to report extortion emails, even when they look like spam. The first message arrived six days before the second one, and the investigation could have started then.